Parul® University
Vadodara, Gujarat

NAAC GRADE A++

Information and Communication Technology

Metasploit Frame work 303105324

Mr Bibungsarth Islary
Assistant Professor
CSE (Cyber Security)

Content

1. Wireless Security Fundamentals
2. Wireless Attack Surface
3. Metasploit and Wireless Networks
4. Wireless Reconnaissance
5. Authentication and Association
6. Evil Twin Attack
7. Rogue Access Point
8. Karmetasploit
9. Wireless MITM
10. Traffic Interception
11. Credential Security
12. SMB Relay
13. Case Studies

WIRELESS NETWORK PENETRATION TESTING

What is Wireless Penetration Testing?

Wireless penetration testing evaluates the security of Wi-Fi networks and connected clients.

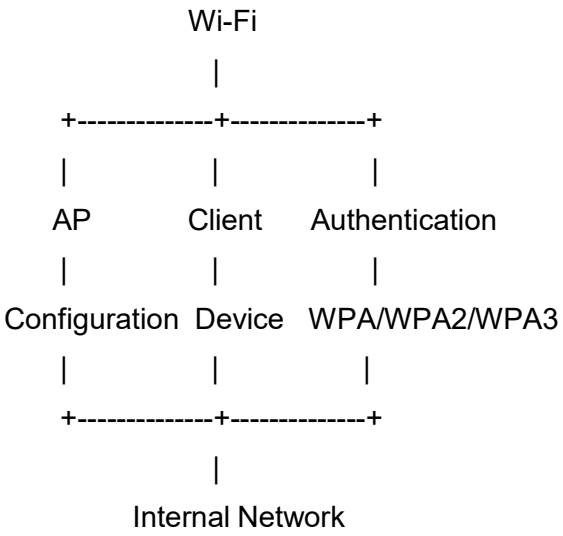
Objectives

- Identify wireless security weaknesses
- Evaluate authentication
- Identify rogue access points
- Test client behavior
- Analyze network segmentation
- Validate monitoring controls

Tester
↓
Wireless Network
↓
Access Point
↓
Client
↓
Internal Network

Important: Testing should be performed only on an authorized wireless lab.

Wireless Attack Surface



Possible targets:

- Access points
- Wireless clients
- Authentication mechanisms
- Encryption configuration
- Network segmentation
- Roaming behavior
- Management interfaces

Wireless Communication

Basic communication:

Client

⇅

Radio / Wireless Medium

⇅

Access Point

↓

Network

Unlike wired networks, wireless communication occurs through a shared radio medium.

An attacker may be able to observe wireless management and communication activity without physically connecting a cable.

Wireless Components

Access Point

Provides wireless connectivity.

Station / Client

Device connecting to the AP.

Wireless Controller

May centrally manage multiple APs.

Authentication Infrastructure

May include:

- PSK
- 802.1X
- RADIUS

Client → AP → Authentication → Network

Wireless Security

Common security models:

- Open network
- WEP
- WPA
- WPA2
- WPA3
- WPA/WPA2 Enterprise
- 802.1X

Security evolution

WEP

↓

WPA

↓

WPA2

↓

WPA3

Wireless security depends on both **protocol security and configuration**.

Wireless Testing Methodology

Scope
↓
Reconnaissance
↓
Identify APs
↓
Identify Clients
↓
Analyze Security
↓
Controlled Attack Simulation
↓
Observe Detection
↓
Document Findings

Before testing Define:

- Authorized SSIDs
- Authorized devices
- Test location
- Testing time
- Permitted techniques

Metasploit and Wireless Networks

Metasploit is primarily an exploitation and security testing framework.

Wireless testing may involve Metasploit together with other wireless tools.

Wireless Recon

↓

Wireless Assessment

↓

Metasploit

↓

Controlled Exploitation

↓

Session / Validation

Metasploit is not itself a complete wireless auditing platform.

Role of Metasploit

Metasploit can support:

- Exploit development
- Exploit execution
- Payload handling
- Session management
- Post-exploitation
- Auxiliary testing

Wireless testing may require additional components for:

- Packet capture
- Monitor mode
- AP emulation
- Wireless frame analysis

Wireless Reconnaissance

Identify:

- SSID
- BSSID
- Channel
- Encryption
- Authentication
- Signal characteristics
- Connected clients

Conceptually:

Wireless Environment

↓

Access Points

↓

SSID / BSSID

↓

Security Configuration

↓

Potential Attack Surface

SSID vs BSSID

SSID

The network name visible to users.

Example:

University-WiFi

BSSID

The MAC address associated with a wireless AP/interface.

SSID
↓
BSSID
↓
Specific AP

Multiple APs can advertise the same SSID.

Wireless Channels

Wireless networks operate on radio channels.

2.4 GHz

├── Channel 1

├── Channel 6

└── Channel 11

Other bands include:

- 5 GHz
- 6 GHz

Channel information helps identify:

- Nearby APs
- Overlapping networks
- Rogue APs
- Wireless interference

Wireless Authentication

Two broad models:

Personal

Uses a shared secret / PSK.

Client → AP → PSK

Enterprise

Uses centralized authentication such as 802.1X/RADIUS.

Client → AP → 802.1X → Authentication Server

Evil Twin Attack

An Evil Twin is a rogue access point designed to imitate a legitimate wireless network.

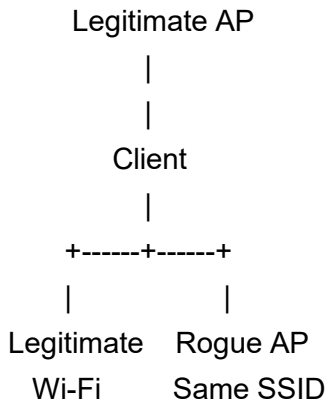
Legitimate AP
SSID: Campus-WiFi

+

Rogue AP
SSID: Campus-WiFi

A victim may mistakenly connect to the rogue AP.

Evil Twin Attack



Trick a client into associating with the attacker-controlled network.

Evil Twin Attack Chain

Identify Target SSID

↓

Observe Wireless Environment

↓

Rogue AP Appears

↓

Client Selects / Associates

↓

Attacker-Controlled Network

↓

Traffic / Authentication Observation

↓

Potential MITM

The Evil Twin attack abuses **trust in network identity**.

Why Can Clients Connect?

Clients may make decisions based on:

- SSID
- Previous network profiles
- Signal strength
- Authentication configuration
- User selection
- Roaming behavior

Matching the SSID does not prove that the AP is legitimate.

Evil Twin vs Rogue AP

Rogue AP	Evil Twin
Unauthorized AP	Specifically imitates a legitimate AP
May use different SSID	Usually copies SSID
Can be accidental or malicious	Typically deliberate impersonation
May provide unauthorized access	Attempts to attract legitimate clients

EVIL TWIN SECURITY IMPACT

Potential consequences:

- Traffic interception
- Credential exposure
- Phishing
- Malware delivery
- Session theft
- Network reconnaissance

Victim

↓

Rogue AP

↓

Attacker

↓

Internet / Internal Services

Detecting an Evil Twin

Monitor:

- Duplicate SSIDs
- Unexpected BSSID
- Unexpected AP location
- Channel changes
- Authentication differences
- Signal anomalies
- Wireless controller alerts

Same SSID

+

Different BSSID

+

Unexpected Location

↓

Potential Rogue AP

Defending Against Evil Twin Attacks

Controls include:

- WPA2/WPA3
- 802.1X Enterprise authentication
- Certificate validation
- Wireless intrusion detection
- Wireless intrusion prevention
- Client configuration policies
- User awareness

Users should not treat an SSID name alone as proof of network authenticity.

Karmetasploit

Karmetasploit is a Metasploit-based framework/workflow historically associated with wireless client interaction and the **Karma attack concept**.

The basic idea involves responding to wireless client requests in a controlled testing environment.

Wireless Client

↓

Network Discovery / Probe

↓

Rogue AP

↓

Client Interaction

↓

Controlled Assessment

KARMA ATTACK CONCEPT

A client may search for networks it previously knows.

Conceptually:

Client

↓

"Where is Network-X?"

↓

Rogue AP responds

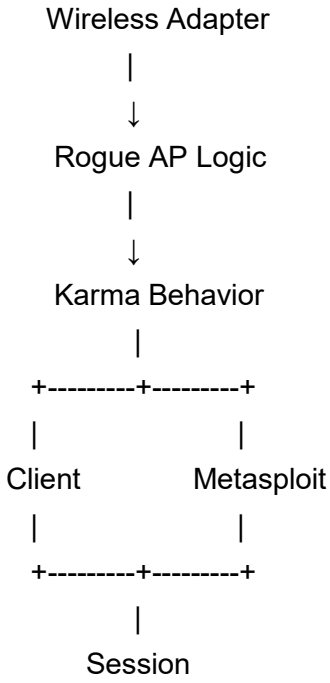
↓

Client connects

Security weakness

The client may trust a network based on its expected identity rather than cryptographically proving the AP's identity.

Karmetasploit Architecture



Purpose

Study client behavior and wireless trust relationships in an authorized lab.

Karmetasploit Configuration

A controlled lab requires:

- Compatible wireless adapter
- Monitor/injection capability where required
- Isolated test environment
- Metasploit Framework
- Wireless configuration
- Defined test SSIDs
- Test client

Conceptual workflow:

Wireless Adapter

↓

Monitor / AP Setup

↓

Karma Configuration

↓

Metasploit Integration

↓

Test Client

Karma Configuration Logic

The important concept is **client-driven network discovery**.

Test Client

↓

Wireless Network Discovery

↓

Client searches for known network

↓

Karma-style test environment responds

↓

Client may attempt association

↓

Test Environment

- Which SSID the client requests
- Which AP responds
- Which BSSID is presented
- Whether the client associates
- What IP configuration it receives
- What network traffic follows

The objective of the lab is to understand the trust relationship, not to collect real credentials.

Karmetasploit Workflow

Prepare Lab

↓

Configure Wireless Interface

↓

Configure Rogue AP

↓

Enable Karma Behavior

↓

Start Metasploit Components

↓

Connect Test Client

↓

Observe Client Behavior

↓

Collect Evidence

Detecting Karma-Style Attacks

Potential indicators:

- Unexpected AP responses
- Duplicate SSIDs
- Client association with unknown BSSID
- Multiple SSIDs appearing unexpectedly
- Unusual wireless management frames
- Unexpected network configuration

Wireless Man-in-the-Middle

A wireless MITM attack attempts to place the attacker between a client and its intended destination.

Client

↓

Attacker / Rogue AP

↓

Network

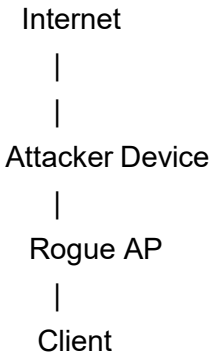
↓

Destination

Potential objectives:

- Observe traffic
- Modify traffic
- Redirect traffic
- Capture metadata

Wireless MITM



The attacker controls the intermediate network path.

WIRELESS MITM ATTACK CHAIN

Reconnaissance

↓

Rogue AP

↓

Client Association

↓

Traffic Forwarding

↓

Traffic Observation

↓

Potential Modification

A MITM attack becomes possible when the attacker can control or influence the communication path.

WHAT CAN MITM REVEAL?

Depending on protocol security, an attacker may observe:

- Source/destination
- DNS requests
- Metadata
- Unencrypted HTTP content
- Connection timing
- Traffic volume

Strong encryption can protect:

- Credentials
- Application content
- Session data

MITM does not automatically defeat TLS.

HTTPS AND WIRELESS MITM

HTTPS Protection

Without TLS:

Client → Attacker → Server

↓

Read / Modify

With properly validated TLS:

Client → TLS → Server

↓

Protected

A rogue Wi-Fi network does not automatically make encrypted HTTPS traffic readable.

Detecting Wireless MITM

Monitor:

- Duplicate BSSID/SSID combinations
- Unexpected gateway
- ARP anomalies
- DNS anomalies
- Certificate warnings
- Wireless association changes
- Unexpected traffic paths

Wireless Anomaly
+
Gateway Change
+
DNS Anomaly
↓
Potential MITM

WIRELESS MITM DEFENSE

- WPA2/WPA3
- Enterprise authentication
- Certificate validation
- VPN for untrusted networks
- HTTPS
- HSTS
- Wireless monitoring
- Network segmentation
- Client isolation

SMB Relay Attack

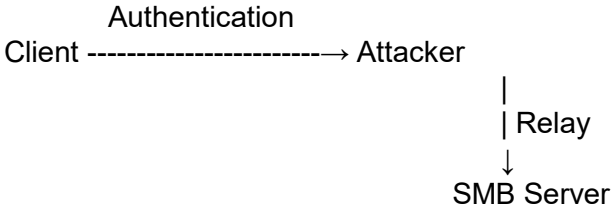
An SMB relay attack involves forwarding authentication attempts from one system to another instead of directly compromising the user's password.

Conceptually:

Client
|
| Authentication
↓
Attacker
|
| Relay
↓
Target SMB Server

The attacker abuses authentication forwarding rather than necessarily knowing the user's password.

SMB Relay Architecture



The attacker acts as an intermediary.x

SMB Relay Attack Chain

Client Authentication

↓

Authentication Interception

↓

Relay

↓

Target SMB Service

↓

Authentication Accepted

↓

Unauthorized Access / Action

The attack depends on the authentication protocol, target configuration, and whether protections prevent relay.

SMB Relay Conditions

Potential enabling conditions include:

- Authentication protocols that permit relay
- Inadequate signing protections
- Network positioning
- Weak segmentation
- Services accepting relayed authentication

Authentication should prove not only **who** is authenticating but also protect the integrity and intended destination of the authentication exchange.

SMB Signing

SMB signing helps protect the integrity and authenticity of SMB messages.

Conceptually:

Client

↓

Signed SMB Messages

↓

Server

SMB signing can reduce exposure to certain relay scenarios.

Relay vs Password Attack

SMB Relay	Password Attack
Forwards authentication	Attempts to discover password
May not require password knowledge	Requires password guessing/cracking
Depends on protocol/configuration	Depends on credential strength
Abuses authentication flow	Attacks credential secrecy

Relay attacks target the **authentication process**, not necessarily the password itself.

SMB Relay Detection

Monitor:

- Unusual SMB authentication
- Unexpected source/destination pairs
- NTLM authentication patterns
- Multiple authentication attempts
- SMB connections from unusual hosts
- Privileged account usage

Unexpected Client

+

Authentication

+

Unexpected SMB Target

↓

Investigate Possible Relay

Defending Against SMB Relay

Important controls:

- SMB signing
- Prefer stronger authentication mechanisms where appropriate
- Reduce unnecessary NTLM usage
- Network segmentation
- Restrict SMB exposure
- Disable unnecessary services
- Monitor authentication flows
- Least privilege

Evil Twin vs Wireless MITM

Evil Twin	Wireless MITM
Impersonates AP	Intercepts communication path
Focuses on client association	Focuses on traffic
May lead to MITM	Requires traffic interception position
Uses wireless trust	Uses path/control of communication

Evil Twin
↓
Client Association
↓
Possible MITM

Karma vs Evil Twin

Evil Twin

Imitates a known legitimate network.

Karma

Can respond to client network-discovery behavior and attract clients based on requested network identities.

Evil Twin

Known SSID

↓

Impersonation

Karma

Client Probe / Request

↓

Rogue Response

Wireless Attack Comparison

Attack	Primary Target	Main Idea
Evil Twin	Client	Fake legitimate AP
Karma	Client	Respond to client network requests
Wireless MITM	Traffic path	Intercept communication
SMB Relay	Authentication	Forward authentication
Rogue AP	Wireless network	Unauthorized AP

Case Study: Evil Twin

A university network uses:

SSID: University-WiFi

A second AP appears using the same SSID.

The second AP has:

- Different BSSID
- Different physical location
- Different security configuration

Questions

1. What is the likely attack?
2. Which evidence supports your conclusion?
3. What should the wireless administrator investigate?
4. How could clients detect the difference?
5. What controls could prevent the attack?

Case Study: Wireless MITM

A laptop connects to an unknown wireless network.

After association:

- Gateway changes
- DNS behavior changes
- HTTP traffic is observed
- HTTPS remains encrypted

Questions

1. What attack position may exist?
2. Which traffic is potentially exposed?
3. Why does HTTPS remain protected?
4. What evidence should be collected?
5. Which controls could reduce the risk?

Parul® University | NAAC GRADE A++

https://paruluniversity.ac.in/

